

Student Name	Oluwatosin Olajubu
Reg. No	C11/26/CGRCE/17602

NexusTech Solutions

Information Security Policy Framework — Week 2 Practical Laboratory

NexusTech Solutions | GRC102 – Information Security Governance | Week 2

Executive Summary

NexusTech’s rapid growth from 50 to 250 employees and expansion into financial and healthcare clients make the former five-year-old “IT Rules” document unsuitable as the organisation’s primary security governance mechanism. This report establishes a maintainable documentation hierarchy, separates policy intent from standards, guidelines and procedures, and applies a Security Policy Development Lifecycle to five practical governance artefacts.

The framework provides an enforceable Acceptable Use Policy, a sequential User Access Request Procedure, a role-based communication and training plan, and a trigger-based policy review mechanism. The design is intended to support security governance and readiness activities relevant to ISO/IEC 27001 and SOC 2 without treating either as a checklist or claiming certification.

Evidence Bundle 1 — Security Policy Hierarchy & Categorisation

1. Purpose

This bundle establishes a four-level documentation hierarchy for NexusTech and applies it to the eight statements supplied in the laboratory scenario. The hierarchy separates management intent from mandatory technical requirements, recommended practices and repeatable operational steps.

2. Hierarchy Definition

Document type	Purpose	Authority	Nature	Level of detail
Policy	Sets organisational direction, intent, principles and mandatory requirements.	Executive/management approval; highest internal authority.	Mandatory.	High-level; defines what and why.
Standard	Defines specific, measurable mandatory requirements that support policy.	Policy owner / designated governance authority.	Mandatory.	More specific; measurable control or configuration requirements.
Guideline	Provides recommended practices or advice to help users achieve secure outcomes.	Policy owner / security function.	Recommended unless explicitly adopted as mandatory.	Practical guidance; flexible.
Procedure	Defines the repeatable steps used to implement a policy or standard.	Process/system owner under policy authority.	Mandatory when the governing policy/process requires it.	Detailed, sequential and action-oriented.

3. Documentation Hierarchy

Direction flows downward from organisational policy into measurable standards and operational procedures, while guidelines support implementation. Evidence and performance information flow upward for monitoring, review and improvement.



Implementation evidence → monitoring → management review → policy improvement

4. Statement Categorisation

#	Statement type	Classification	Justification
1	All NexusTech employees must use MFA when accessing the corporate network remotely.	Policy	It establishes a mandatory organisational requirement without prescribing implementation steps.
2	To configure MFA on your mobile device, download the Authenticator app, scan the QR code, and enter the six-digit code.	Procedure	It gives sequential instructions for completing a specific operational task.
3	It is recommended that developers use parameterised queries to reduce SQL injection risk.	Guideline	It recommends a risk-reducing practice rather than imposing a mandatory requirement.
4	NexusTech is committed to protecting the confidentiality, integrity and availability of all client data.	Policy	It expresses high-level organisational security intent and principles.
5	All corporate laptops must have full-disk encryption enabled using BitLocker (Windows) or FileVault (macOS).	Standard	It defines a specific, measurable mandatory technical requirement supporting security policy.
6	Employees should avoid connecting to public, unsecured Wi-Fi networks when travelling.	Guideline	It provides recommended user behaviour without prescribing an absolute requirement.
7	In the event of a suspected security breach, employees must immediately contact the IT Helpdesk at extension 5555.	Procedure	It defines an immediate operational action and reporting route following an event.
8	Passwords must be a minimum of 14 characters and contain uppercase, lowercase, number and special character.	Standard	It sets measurable mandatory authentication requirements rather than describing process steps.

5. Lifecycle Application

NexusTech should manage each document through a controlled lifecycle: identify business/regulatory drivers → assess risk and requirements → draft → consult stakeholders → review and approve → publish and communicate → implement → monitor compliance and effectiveness → review after defined intervals or trigger events → revise, approve and retire superseded versions. This prevents the former five-year-old “IT Rules” document from becoming a static repository of mixed requirements.

6. Governance Outcome

The framework gives each requirement a clear home, owner, authority level and maintenance path. It also supports evidence generation for an ISMS and control environment without treating ISO/IEC 27001, NIST CSF or SOC 2 as identical frameworks.

Evidence Bundle 2 — Acceptable Use Policy

Document Control

Field	Approved entry
Title	Acceptable Use Policy
Version	1.0
Policy Owner	Information Security Manager
Approval Authority	Marcus Vance, CEO
Effective Date	18 September 2026
Review Date	18 September 2027
Classification	Internal
Status	Approved for simulation

1. Purpose

This policy establishes acceptable and prohibited use of NexusTech information systems, devices, networks, applications and data. It is intended to reduce security, privacy, operational and compliance risks while allowing reasonable business use of company technology.

2. Scope

This policy applies to all employees, contractors, interns, consultants and other authorised users who access NexusTech systems or information, including company-managed endpoints, cloud services, corporate networks, business applications and information handled on behalf of clients.

3. Policy Statements

- 3.1. Users must use NexusTech systems, accounts and information primarily for authorised business purposes and in accordance with their role and access rights.
- 3.2. Users must protect credentials, authentication factors and company devices from unauthorised access and must not share passwords or authentication codes.
- 3.3. Users must access, use, copy, transmit and disclose information only when authorised and only to the extent necessary for legitimate business purposes.
- 3.4. Users must not install, download or use software, browser extensions, scripts or services that have not been approved through the applicable NexusTech process.
- 3.5. Users must not disable, bypass or interfere with security controls, endpoint protection, logging, monitoring, access controls or other safeguards.
- 3.6. Users must not use NexusTech systems to conduct unlawful activity, harassment, discrimination, fraud, unauthorised commercial activity, or activity that creates material security or reputational risk.
- 3.7. Users must not use personal cloud storage, personal email, removable media or other unauthorised external services to store or transfer NexusTech or client information.
- 3.8. Users must not introduce malicious code, attempt unauthorised security testing, scan systems, exploit vulnerabilities or access resources beyond their authorised permissions.
- 3.9. Users must promptly report suspected loss, compromise, malware, unauthorised access, data exposure or other security incidents through the approved reporting channel.
- 3.10. Limited personal use is permitted when it is lawful, reasonable, does not interfere with work, does not consume excessive resources, does not create security risk and does not breach any NexusTech policy.
- 3.11. Users must comply with applicable contractual, privacy, confidentiality, intellectual property and information security requirements when using NexusTech resources.
- 3.12. Users should assume that activity on company-managed systems may be logged or monitored in accordance with applicable law, organisational policy and legitimate security purposes.

4. Roles and Responsibilities

Role	Responsibilities
Users	Read and comply with the AUP; protect credentials and information; report incidents; complete required training.

IT / Security	Implement and monitor technical controls; provide guidance; investigate suspected misuse; maintain supporting procedures and evidence.
Managers	Ensure team members understand role-specific requirements; approve access appropriately; address repeated non-compliance.
HR	Support disciplinary processes where policy breaches are substantiated and ensure employment processes are applied consistently.
Information Security Manager	Own the policy, coordinate reviews, maintain exceptions and report material compliance issues to governance forums.

5. Compliance and Enforcement

NexusTech may investigate suspected violations using appropriate evidence and due process. Confirmed breaches may result in corrective action, removal or restriction of access, mandatory retraining and/or disciplinary action in accordance with applicable employment arrangements and law. Serious matters may be escalated to executive management, legal counsel, clients or regulators where required.

6. Exceptions

Exceptions must be documented, risk-assessed, time-bound and approved by the Information Security Manager and relevant business/data owner. High-risk exceptions require executive approval. Compensating controls and an expiry/review date must be recorded. Users must not self-authorise an exception.

7. Approval and Review

Approved by: Marcus Vance, CEO. Policy Owner: Information Security Manager.

The policy is reviewed at least annually and earlier when material technology, business, regulatory, contractual, security or incident changes occur.

8. Related Documents

User Access Request Procedure; Information Security Policy; Incident Management Procedure; Information Classification and Handling Standard; Endpoint Security Standard; Software Installation/Change Management Procedure.

Evidence Bundle 3 — User Access Request Procedure

Document Control

Field	Entry
Procedure Owner	IT Service Desk / Information Security Manager
Version	1.0
Effective Date	18 September 2026
Review Cycle	Annual and trigger-based
Applies to	Employees, contractors and authorised third parties

1. Purpose and Scope

This procedure ensures that access to NexusTech systems is requested, authorised, provisioned and evidenced consistently. It applies to new access, additional access, role changes and other non-emergency access changes.

2. Prerequisites

The technician must have access to the approved ticket/workflow system, identity and access management capability, the relevant system owner/data owner approval route, and current role/access information. Only authorised Helpdesk/IT personnel may provision access.

3. Sequential Procedure

- 1. Receive request:** Accept only an approved ticket/workflow request. Do not act solely on informal email, chat or verbal requests.
- 2. Validate requester:** Confirm the requester's identity and employment/contract status using approved records.
- 3. Confirm business need:** Check that the requested system, role and access level are stated and linked to a legitimate business need.
- 4. Verify approvals:** Confirm manager approval and, where required by the system or data classification, data-owner/system-owner approval. Reject or return incomplete requests.
- 5. Check segregation and conflicts:** Review existing access for excessive privilege, incompatible duties or duplicate permissions. Escalate conflicts before provisioning.
- 6. Provision account:** Create or enable the account through the approved identity/account-management process. Do not create shared accounts unless formally authorised.
- 7. Assign role-based access:** Apply the approved role/profile and least-privilege permissions. Grant only the access explicitly authorised.
- 8. Apply security requirements:** Ensure required MFA, device or authentication controls are applied before access is activated where technically applicable.
- 9. Validate:** Perform a high-level verification that the account and permissions match the approved request without accessing unnecessary user data.
- 10. Notify:** Notify the user and manager through the approved channel that access has been provisioned, including any required onboarding or security instructions.
- 11. Capture evidence:** Record approvals, actions taken, date/time, technician identity, access profile and any exception/compensating control in the ticket.
- 12. Close ticket:** Set the ticket to the appropriate completed status only after evidence is attached and required notifications have been sent.

4. Emergency / Exceptional Requests

Emergency access may be granted only where delay would create material business or security impact. The technician must obtain the designated emergency authorisation, apply the minimum necessary access, record the reason and duration, and ensure retrospective approval/review within one business day. Emergency access must be removed or normalised when the emergency ends.

5. Audit Trail and Retention

Access requests and supporting approval/evidence must be retained in the approved ticketing or governance repository in accordance with NexusTech's records-retention requirements. Tickets must be sufficiently complete to demonstrate who requested, approved, provisioned and reviewed access.

6. Control Checks

Control point	Pass condition
Authorisation	Required manager/data-owner approvals are present before provisioning.
Least privilege	Provisioned role matches the approved business need.
Identity	Requester and target user are verified.

Evidence	Ticket contains approvals, actions and timestamps.
Emergency access	Reason, scope, duration and retrospective review are recorded.

Evidence Bundle 4 — Communication & Training Plan

1. Rollout Objective

The rollout will move the AUP from an approved document to understood and evidenced behaviour. Communication will be role-specific, training will be mandatory for in-scope personnel, and effectiveness will be measured rather than assumed from email delivery.

2. Communication and Training Plan

Audience	Key message	Channel	Owner	Timing	Acknowledgement	Success measure
General employees	What acceptable use means; prohibited activities; personal cloud/software restrictions; incident reporting.	All-hands launch; email; intranet; mandatory e-learning.	Information Security + HR	Day 1–7	Digital attestation after module	≥95% completion and ≥90% knowledge-check pass rate.
IT / Helpdesk	AUP technical implications; access, software, endpoint and incident-reporting expectations.	Technical briefing; procedure walkthrough; LMS module.	Information Security + IT Director	Day 3–10	Training attendance + attestation	100% completion; 100% of sampled tickets align with procedure.
Managers	Manager accountability; approvals; escalation; handling repeated non-compliance.	Manager briefing; intranet manager pack; email.	Information Security + HR	Day 5–10	Manager acknowledgement	≥95% acknowledgement; escalation routes understood.
HR / People team	Policy breach handling, retraining and disciplinary escalation.	HR workshop; policy pack.	Information Security + HR	Day 5–10	Acknowledgement	100% completion; documented escalation workflow.
New joiners	Core AUP expectations before system access or within onboarding window.	Onboarding LMS + acknowledgement.	HR + IT	Ongoing	Electronic attestation	100% acknowledgement before/at onboarding checkpoint.

3. Rollout Timeline

Timing	Activity	Output
Day 1	CEO announcement and intranet publication	Visible executive sponsorship and published policy
Days 2–7	Mandatory learning module and knowledge check	Training records and assessment results
Days 3–10	IT and manager role-based sessions	Role-specific understanding and attendance evidence
Day 10	Attestation deadline and exception follow-up	Signed/digital acknowledgements; exception list

Days 11–30	Targeted reminders and remediation	Outstanding completion closed; repeat issues identified
Day 30	Effectiveness review	Completion, acknowledgement, knowledge and incident trends reported

4. Non-Compliance and Escalation

Outstanding training or attestation after the deadline will trigger automated reminders, followed by manager escalation. Repeated misunderstanding will result in targeted retraining. Suspected deliberate or material AUP violations will be handled through the security investigation and HR/management escalation process rather than treated as a training-completion issue.

5. Effectiveness Measures

Core measures: training completion rate; acknowledgement/attestation rate; knowledge-check pass rate; number and type of AUP-related incidents; repeat incidents after remediation; and a sample of operational evidence such as software-installation or access tickets. Results should be reviewed after rollout and incorporated into the next policy review.

Evidence Bundle 5 — Policy Review & Maintenance Memo

Policy Review Memo

To	Information Security Steering Committee
From	Information Security Manager
Date	18 September 2027
Subject	AUP Review Following AWS Migration and Personal-Cloud Sharing Incident

The Acceptable Use Policy should be formally reviewed because two material trigger events have occurred since its approval:

- First, NexusTech migrated its primary database to AWS, changing the technology environment, responsibilities and cloud-service usage patterns addressed by acceptable-use requirements. The review should confirm that the AUP remains aligned with authorised cloud services, data handling, access, monitoring and use of company information in cloud environments.
- Second, an employee shared a sensitive document through a personal cloud-storage account. This incident demonstrates a need to test whether the current prohibition on personal cloud storage is sufficiently clear, understood and supported by preventive and detective controls.

The review should involve Information Security, IT/Cloud Engineering, relevant data/system owners, Legal/Privacy, HR and business representatives. The team should examine the incident record, user feedback, training and acknowledgement results, access and cloud-usage evidence, and any relevant contractual or regulatory requirements, then assess residual risk and document proposed changes.

At minimum, the revised AUP should explicitly prohibit the use of personal cloud storage and personal file-sharing services for NexusTech or client information, and should clarify that only approved corporate cloud services may be used for business data. It should also add a clear requirement to report accidental external sharing promptly and preserve the evidence needed for investigation.

The Information Security Manager remains the policy owner.

The revised policy should follow the controlled approval route to the CEO, with material risk, legal or client-impact issues escalated through the Information Security Steering Committee before approval. The AUP should be reviewed at

least annually, with an early review triggered by material cloud/platform changes, significant security or data incidents, major changes in client/regulatory obligations, or evidence that the policy is no longer effective.

Security Policy Development Lifecycle Applied

Stage	NexusTech application
1. Identify drivers	Growth, financial/healthcare clients, outdated documentation, inconsistent practice and compliance/readiness needs.
2. Assess risk and requirements	Consider information assets, users, technology, client commitments, security incidents and applicable obligations.
3. Draft	Separate policy, standard, guideline and procedure content; use clear ownership and mandatory language.
4. Consult	Engage IT, Security, managers, HR, data/system owners, Legal/Privacy and business stakeholders as relevant.
5. Approve	Use defined authority: policy owner prepares; designated governance/executive authority approves.
6. Publish & communicate	Controlled publication, role-based training, acknowledgement and accessible supporting procedures.
7. Implement & monitor	Operationalise requirements through tickets, access controls, endpoint controls, training and evidence collection.
8. Review & improve	Annual review plus event-driven review after material technology, business, regulatory or security changes.

References

GRC102 Week 2 course material: Developing Security Policies and Procedures.

International Organization for Standardization (ISO). ISO/IEC 27001:2022 — Information security, cybersecurity and privacy protection — Information security management systems — Requirements. Official ISO standard page. Accessed 17 September 2026.

National Institute of Standards and Technology (NIST). (2024). The NIST Cybersecurity Framework (CSF) 2.0, CSWP 29. Accessed 17 September 2026.

AICPA & CIMA. (2023). 2017 Trust Services Criteria (with Revised Points of Focus — 2022). Accessed 17 September 2026.